

DOCUMENTO DE REQUISITO

Gestão de Fornecedores Projeto Integrado - PNCP Data Engine

Desenvolvido por: Lucas Ferreira de Vasconcelos Ribeiro, Luan Martins de Souza, Isaac Daniel Alvares Diniz, Antonio Tenorio Ferreira de Souza, Arthur Orange Vanderlei de Souza, Pedro Andre Falcao de Souza, Priscilla Maciel de Lima, Joao Lucas Santos Lira, Guilherme Chaves Sena

GitHub: <https://github.com/Lukitas20-beep/ProjEngDados>

Campo	Descrição
Requisito avaliado	6 - Gestão de fornecedores
Período de documentação	10-11/06
Data de avaliação da implementação	10-11/06
Sistema	Aplicação Streamlit para extração, transformação, visualização e carga de dados do PNCP
Versão do documento	1.0

1. Contexto do requisito

O PNCP Data Engine utiliza componentes internos e externos para extrair dados públicos, processar informações, persistir registros, autenticar usuários, executar rotinas de backup e disponibilizar a interface da aplicação. Ao longo das entregas anteriores, o projeto incorporou controles de autenticação, anonimização, LGPD, disponibilidade e continuidade. A sexta entrega consolida esses controles sob a perspectiva da gestão de fornecedores, mapeando APIs, serviços em nuvem, bibliotecas, ferramentas de infraestrutura e dependências relevantes.

Mesmo em um projeto acadêmico, fornecedores e componentes externos representam riscos operacionais, de segurança, de privacidade e de continuidade. Por isso, a aplicação passa a manter inventário de fornecedores, classificação de criticidade, dados tratados, riscos, mitigações, variáveis de ambiente relacionadas e registro de avaliações.

2. Objetivo do requisito

Implementar e documentar um mecanismo básico de gestão de fornecedores no PNCP Data Engine, permitindo identificar quais serviços, APIs, bibliotecas e componentes externos sustentam a aplicação, quais dados são processados por cada um, qual sua criticidade, quais riscos principais existem e quais medidas de mitigação foram adotadas.

3. Escopo da entrega

- Criação de módulo específico para inventário e avaliação de fornecedores.
- Cadastro inicial dos fornecedores e componentes externos usados pelo projeto.
- Classificação por categoria, tipo, criticidade e status.
- Mapeamento de finalidade, dados processados e eventual contato com dados pessoais.
- Registro de riscos principais e medidas de mitigação.
- Checagem de variáveis de ambiente associadas aos fornecedores críticos.

- Registro de avaliações por critério, status, observação e usuário avaliador.
- Exportação do inventário em formato JSON.
- Inclusão da área “Gestão de fornecedores” na aplicação Streamlit.
- Atualização do .env.example e do .gitignore para contemplar a nova camada.

4. Requisitos funcionais

Código	Requisito funcional	Descrição
RF01	Inventário de fornecedores	O sistema deve manter inventário de fornecedores, APIs, bibliotecas e componentes externos usados pelo projeto.
RF02	Classificação de criticidade	O sistema deve classificar fornecedores por criticidade alta, média ou baixa.
RF03	Mapeamento de dados tratados	O sistema deve indicar quais dados ou tipos de dados são processados por cada fornecedor.
RF04	Mapeamento de riscos	O sistema deve registrar risco principal e mitigação associada a cada fornecedor.
RF05	Checagem de configuração	O sistema deve indicar se variáveis de ambiente associadas aos fornecedores estão configuradas.
RF06	Registro de avaliação	O sistema deve permitir registrar avaliação de fornecedor por critério, status e observação.
RF07	Histórico de avaliações	O sistema deve listar avaliações recentes registradas pelos usuários autenticados.
RF08	Exportação do inventário	O sistema deve permitir baixar o inventário de fornecedores em JSON.
RF09	Interface de governança	A aplicação deve exibir a área Gestão de fornecedores dentro do fluxo autenticado.

5. Requisitos não funcionais

Código	Requisito não funcional	Descrição
RNF01	Rastreabilidade	Avaliações de fornecedores devem registrar data, critério, status, observação e usuário avaliador.
RNF02	Manutenibilidade	A lógica de fornecedores deve ficar concentrada em módulo próprio, separado da interface principal.
RNF03	Transparência	A aplicação deve expor finalidade, riscos e mitigação de cada fornecedor de forma clara.
RNF04	Segurança	Fornecedores críticos devem estar associados a variáveis de ambiente, sem credenciais no código-fonte.
RNF05	Continuidade	Fornecedores críticos devem ser avaliados quanto a riscos de indisponibilidade e dependência externa.
RNF06	Baixo impacto	A gestão de fornecedores não deve interromper o fluxo principal de busca, processamento e carga.
RNF07	Portabilidade operacional	O inventário deve poder ser exportado em JSON para documentação e auditoria acadêmica.

6. Regra de negócio

A área de gestão de fornecedores só deve estar disponível para usuário autenticado e com aceite da política de privacidade vigente. O sistema mantém um inventário inicial de fornecedores e componentes associados ao projeto, incluindo PNCP, MongoDB Atlas, Groq, Streamlit, Prefect, Kafka, PySpark, Docker e bibliotecas Python. Cada item deve possuir finalidade, categoria, criticidade, dados processados, risco principal, mitigação e status de uso.

As avaliações de fornecedores não substituem contratos, SLAs ou análise jurídica formal, mas servem como evidência acadêmica de governança, acompanhamento e consciência dos riscos de terceiros. Quando o fornecedor depende de credenciais, o sistema deve indicar as variáveis de ambiente relacionadas, reforçando que chaves e URIs não devem ser versionadas no Git.

7. Fluxo de gestão de fornecedores

- O usuário autenticado acessa a área “Gestão de fornecedores”.
- O sistema inicializa o inventário padrão de fornecedores e componentes do projeto.
- A interface exhibe fornecedores, categorias, finalidades, criticidades, riscos e mitigações.
- O usuário pode baixar o inventário em JSON.
- O sistema mostra checagem de variáveis de ambiente por fornecedor.
- O usuário pode registrar avaliação por critério e status.
- A aplicação salva a avaliação em banco local e exhibe o histórico recente.
- Eventos de avaliação são registrados também como eventos de segurança e privacidade.

8. Fornecedores e componentes mapeados

Fornecedor/ componente	Categoria	Criticidade	Risco principal	Mitigação
PNCP API	API pública governamental	Alta	Indisponibilidade ou mudança de retorno da API	Timeout, retentativas, validação de entrada e tratamento de erro.
MongoDB Atlas	Banco em nuvem	Alta	Exposição de credenciais ou indisponibilidade do banco	Variável MONGO_URI, health check, backup JSONL e anonimização.
Groq API	Classificação por IA	Média	Dependência externa e envio de texto excessivo	Validação e limite do texto antes da chamada.
Streamlit	Framework de interface	Alta	Falhas de sessão ou exposição de tela	Autenticação, sessão e bloqueio sem aceite LGPD.
Prefect	Orquestração	Média	Falha em execução automatizada	Execução manual alternativa e variáveis de ambiente.
Kafka/kafka-python	Mensageria	Baixa	Complexidade operacional	Uso mapeado e fora do fluxo principal crítico.
PySpark/Spark	Processamento	Baixa	Dependência de ambiente específico	Uso alternativo e documentação.
Docker/Docker Compose	Ambiente	Média	Exposição de variáveis ou imagens desatualizadas	.env, .gitignore e revisão de configuração.
Bibliotecas Python	Dependências open source	Média	Vulnerabilidades e incompatibilidades	Inventário, requirements e revisão periódica.

9. Critérios de avaliação de fornecedores

Critério	Uso na aplicação
Segurança da informação	Verifica riscos de credenciais, acesso, exposição de dados e dependência técnica.
Privacidade e LGPD	Verifica se há dados pessoais ou possibilidade de tratamento identificável.
Disponibilidade	Avalia impacto de indisponibilidade do fornecedor no uso da aplicação.
Continuidade operacional	Verifica se há alternativa, backup, exportação ou mitigação em caso de falha.
Dependência tecnológica	Avalia grau de acoplamento do projeto ao fornecedor.
Adequação ao escopo acadêmico	Avalia se o uso do fornecedor é proporcional ao projeto integrado.

10. Critérios de aceite

Critério	Resultado esperado
Inventário exibido	A aplicação deve mostrar fornecedores e componentes externos em tabela.
Exportação JSON	O usuário deve conseguir baixar o inventário de fornecedores em JSON.
Criticidade mapeada	Cada fornecedor deve possuir classificação de criticidade.
Riscos e mitigações	Cada fornecedor deve apresentar risco principal e medida de mitigação.
Checação de ambiente	A aplicação deve indicar variáveis de ambiente configuradas ou ausentes.
Registro de avaliação	O usuário deve conseguir registrar avaliação por critério, status e observação.
Histórico de avaliações	A aplicação deve listar avaliações recentes.
Credenciais	Nenhuma credencial de fornecedor deve ser salva diretamente no código-fonte.

11. Evidências de implementação

- Criação do módulo `src/vendor\_management.py`, responsável pelo inventário e avaliações de fornecedores.
- Atualização do `app.py` para incluir a área “Gestão de fornecedores”.
- Cadastro inicial de fornecedores e componentes padrão do projeto.
- Criação de banco local `vendors.db` para fornecedores e avaliações.
- Exportação do inventário de fornecedores em JSON.
- Checagem de variáveis de ambiente associadas a fornecedores críticos.
- Registro de eventos de avaliação em logs de segurança e privacidade.
- Atualização do `.env.example` com `VENDOR\_DB\_PATH` e parâmetros complementares.
- Atualização do `.gitignore` para impedir versionamento de bancos locais e arquivos sensíveis.

12. Arquivos impactados

Arquivo	Descrição da alteração
src/vendor_management.py	Novo módulo de inventário, avaliação, exportação e checagem de fornecedores.
app.py	Inclui a área Gestão de fornecedores no fluxo autenticado da aplicação.

.env.example	Inclui variáveis usadas por fornecedores, integrações, backup, segurança e LGPD.
.gitignore	Evita versionamento de bancos locais, logs, backups, variáveis e arquivos sensíveis.
Documentação do Projeto/10_Gestao_Fornecedores.md	Documento técnico em Markdown da Entrega 6.
Documentação do Projeto/6 - Documento_Requisito_Gestao_Fornecedores.docx	Documento formal da Entrega 6.

13. Limitações e melhorias futuras

A solução atende ao escopo acadêmico de gestão de fornecedores, mas não substitui um processo corporativo completo de terceiros. Em uma versão de produção, seria recomendável incluir due diligence formal, contratos, acordos de nível de serviço, revisão periódica de segurança, avaliação jurídica de operadores e controladores, termos de tratamento de dados, monitoramento de vulnerabilidades, inventário automatizado de dependências e responsáveis institucionais por cada fornecedor.

14. Conclusão

A sexta entrega adiciona ao PNCP Data Engine uma camada inicial de governança de fornecedores. O sistema passa a documentar os serviços, APIs, bibliotecas e componentes externos dos quais depende, indicando finalidade, criticidade, riscos, mitigação e configuração. Com isso, o projeto fecha o ciclo das seis entregas avaliadas, conectando autenticação, anonimização, LGPD, proteção contra ataques, backup e gestão de terceiros em uma estrutura coerente de segurança e governança.